CRA Compliance Templates Kit

Oct 31, 2026 · Prepared by [Advisor] · @Aidan Murphy

Ten fill-in templates cover the documents a manufacturer must produce, keep or send under the Cyber Resilience Act (Regulation (EU) 2024/2847). Copy them once per product or product family, fill the [placeholders], and file each result in the technical documentation before the product is placed on the EU market.

Six templates build the evidence for conformity: classification, risk assessment, support period, the Annex VII technical file, the EU declaration and the user information. Four run the product after launch: the vulnerability disclosure policy, the Article 14 notifications, the supplier clause pack and the substantial modification test. Article 14 reporting already applies to products on the market since 11 Sep 2026; the other obligations in these templates apply to units placed from 11 Dec 2027.

Every template carries a worked example for the L2 Smart Lock, an illustrative Class I product of the fictional Example Group. Replace it with your own product's facts.

Template index

Work down the list for each product: templates 1 to 6 in order before placing on the market, 7 to 10 whenever their trigger occurs.

Template	Legal basis	Owner	When	Lands in Annex VII
1 · Product classification record	Arts 6-8; Annexes III-IV; Implementing Regulation (EU) 2025/2392	Product security officer	Before choosing the conformity route; re-run on any change to the product or how it is sold	Pt 1 (core functionality)
2 · Cybersecurity risk assessment	Art 13(2)-(4); Annex I	Product security officer	From the design phase; kept current through the support period	Pt 3
3 · Support period determination	Art 13(8)	Product management	Before placing on the market	Pt 4
4 · Technical documentation index	Art 31; Art 13(13); Annex VII	Compliance lead	Before placing on the market; kept 10 years or the support period, whichever is longer	All points

Template	Legal basis	Owner	When	Lands in Annex VII
5 · EU declaration of conformity	Art 28; Annexes V and VI; Arts 29-30	Compliance lead (executive signs)	After the conformity assessment, before CE marking	Pt 7
6 · User information and instructions	Annex II	Technical writing lead	Accompanies every unit	Pt 1
7 · Vulnerability disclosure policy	Annex I Part II (5)-(6)	PSIRT lead	In place now and for the whole support period	Pt 2(b)
8 · Article 14 notifications	Art 14; Art 69(3)	PSIRT lead; legal reviews the 72-hour and final reports	Live since 11 Sep 2026, for products already on the market	Kept as reporting records
9 · Supplier CRA clause pack	Art 13(5)-(6)	Head of procurement	At sourcing, renewal and supplier change	Pt 3 evidence
10 · Substantial modification assessment	Art 3(30); guidance C(2026) 5252 pts 104-123	Product security officer	Every release, at the release gate	Re-runs templates 1 to 5 when the answer is yes

The companion CRA Product Classifier (D13) produces a record in the same shape as template 1.

How to use the kit

1. Duplicate this doc once per product family, or export a tab to Word and keep it in your evidence system.
2. Replace every [placeholder]. Delete the illustrative L2 Smart Lock column once your own entry is complete.
3. Keep the "Basis" references: a market surveillance authority can ask for the technical documentation, and the references show why each entry is there.
4. Give each completed document a version number and date. Re-issue it, never overwrite it, after a substantial modification (template 10).
5. Get the named approver to sign off before the document enters the technical file.
6. Keep the technical documentation and the declaration for 10 years after placing on the market or for the support period, whichever is longer (Art 13(13)).

Regulatory facts are as at 30 Oct 2026. No harmonised standard is cited in the Official Journal, and no CRA notified body was verifiably designated at checks to 8 Sep 2026. Article and annex references in these templates were checked against the authentic

Official Journal text on 1 Nov 2026; quotations are exact unless marked as paraphrase. The kit supports a documented compliance process and is not legal advice.

CRA Compliance Templates Kit (D14) · v1.0 · 31 Oct 2026 · Prepared by [Advisor]

1 · Product classification record

The product classification record fixes one product's boundary, its single core functionality and its class under Art 7, Art 8, Annex III and Annex IV. The class decides the Art 32 conformity route and whether a notified body is needed. Complete it at design stage, keep it at SKU level and file it in the technical documentation under Annex VII pt 1 (guidance para 144).

The companion interactive tool, CRA Product Classifier (D13), walks the same steps and produces a record in the same shape. Paste its output into this template and add the sign-off.

At a glance

Item	Detail
Legal basis	Art 2(1)-(7); Art 7(1)-(2); Art 8; Annex III; Annex IV; Implementing Regulation (EU) 2025/2392; Art 32
Needed for	Choosing the Art 32 route; stating the core functionality (guidance para 144), recorded in the Annex VII pt 1 general description
Owner	Product security officer
Approver	Product owner and legal counsel
When to create	At concept or design gate, before the risk assessment and before booking a notified body
When to update	On any re-run trigger listed in the template
Retention	With the technical documentation: 10 years after placing or the support period, whichever is longer (Art 13(13))
Feeds	Template 2 (intended purpose); Template 4 (Annex VII pt 1); Template 5 (Annex V pt 7 notified body); Template 10 (re-run on modification)

How to complete

1. Fix the product boundary: hardware, the software needed to use it, and manufacturer-built remote data processing. List separately sold modules as their own products.

2. Write one sentence of core functionality from the instructions, marketing and technical documentation.
3. Run the three Art 2(1) scope conditions, then check each exclusion in Art 2(2)-(7).
4. Compare the core functionality with the 26 technical descriptions in Implementing Regulation 2025/2392. For chips, use the designed AVA_VAN level.
5. Apply the integration and ancillary rules, then the FOSS and AI overlays.
6. Record the result, route and notified-body need. Enter each SKU in the register below and obtain sign-off.

Template

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Record ID and version	[CR-ID], [version], [date]	Annex VII pt 1	CR-L2-01 v1.0, 31 Oct 2026
Product name and identifiers	[Commercial name], [model], [SKU list], [type or serial scheme]	Art 13(15)	L2 Smart Lock; 3 SKUs (see register); Home & Building Solutions
Boundary: hardware	[Physical units and interfaces]	Art 3(1), (5)	Lock body, motor, keypad, BLE and Wi-Fi radio
Boundary: software	[Firmware, apps, drivers needed to use the product]	Art 3(1); guidance para 25	Lock firmware; iOS and Android companion app
Boundary: RDPS	[Manufacturer-built backend functions the product cannot perform without]	Art 3(2); guidance paras 184-196	Access-management cloud: app keys, guest access, access-log sync
Third-party services	[Licensed services treated as components]	Art 13(5); guidance paras 197-202	[None recorded]
Separately sold modules	[Each module sold or licensed separately, with its own record]	Guidance para 145, Example 61	None; each SKU is a complete lock

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Core functionality	[One sentence; one core functionality only]	Guidance paras 139, 144; recorded in the Annex VII pt 1 general description	Controls locking and unlocking of a residential door to protect physical access to the home
Intended purpose and foreseeable use	[Purpose, users, environment, foreseeable use and misuse]	Art 3(23)-(24)	Consumer homes; owner issues app keys and time-limited guest access; foreseeable use on small-office doors
Scope 1: product with digital elements	[Yes or no, with reason]	Art 2(1); Art 3(1)	Yes: hardware with firmware and an app
Scope 2: made available in a commercial activity	[Yes or no, with reason]	Art 2(1); Art 3(22)	Yes: sold at retail across the EU
Scope 3: data connection	[Direct or indirect, logical or physical]	Art 2(1); guidance paras 26-28	Yes: BLE to the app; Wi-Fi to the cloud
Exclusions	[Check medical (2(2)(a)-(b)), vehicles (2(2)(c), 2(5)), aviation (2(3)), marine (2(4)), spare parts (2(6)), defence (2(7))]	Art 2(2)-(7); Delegated Regulation (EU) 2025/1535	None applies
Category match	[Annex III or IV item, or "default"; quote the matching description]	Art 7(1); Implementing Regulation 2025/2392	Annex III Class I item 17: smart home products with security functionalities, including smart door locks

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Chip AVA_VAN level	[Designed level; chips only]	Implementing Regulation 2025/2392; Annex III Class II items 3-4; Annex IV item 3	Not applicable: not a chip product
Integration rule	[Embedded important components; confirm host classified on its own core]	Art 7(1); guidance Example 58	MCU with secure boot is a component; it does not set the lock's class
Ancillary rule	[Extra features that do not change the core]	Implementing Regulation recitals; guidance Examples 59-60	Auto-lock, activity log and battery alerts are ancillary
FOSS overlay	[Is the product itself FOSS with public Annex VII documentation?]	Art 32(5)	No: proprietary product with FOSS components
AI overlay	[Is it a high-risk AI system?]	Art 12; AI Act Art 6	No
Result	[Default / Class I / Class II / Critical]	Art 7; Art 8	Important, Class I
Route	[Module A / B+C / H / certificate]	Art 32; Annex VIII	Module B+C (planned); Module A closed because no harmonised standard is cited (Art 32(2))
Notified body needed	[Yes or no; candidate bodies]	Art 32(2)-(4)	Yes; none designated at checks to 8 Sep 2026; three candidates shortlisted

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Evidence consulted	[Documents read, with versions]	Guidance paras 142-143	Product specification [v], user manual draft [v], retail listing copy, architecture document [v]
Rationale	[Why the core matches, exceeds or falls short of the description]	Annex VII pt 1	Core purpose is physical access protection in homes, which item 17 names expressly
Re-run triggers	[Events that reopen this record]	Classification procedure step 8	New variant or backend; modules sold separately; substantial modification; Art 7(3) act; OJ citation of a standard
Sign-off	[Name, role, date] for product owner, product security officer, legal	Governance	[Name], Product owner, [date]; [Name], Product security officer, [date]; [Name], Legal, [date]

SKU register

SKU	Family	Core functionality	Class / category	Route	Rationale ref	Date	Owner
L2-STD (illustrative)	L2 Smart Lock	Residential door lock control	Class I, Annex III item 17	Module B+C	CR-L2-01	31 Oct 2026	Product security officer
L2-KEY (illustrative)	L2 Smart Lock	Residential door lock control	Class I, Annex III item 17	Module B+C	CR-L2-01	31 Oct 2026	Product security officer
L2-RTF (illustrative)	L2 Smart Lock	Residential door lock control	Class I, Annex III item 17	Module B+C	CR-L2-01	31 Oct 2026	Product security officer

SKU	Family	Core functionality	Class / category	Route	Rationale ref	Date	Owner
[SKU]	[Family]	[Core functionality]	[Class / item or default]	[Route]	[CR-ID]	[Date]	[Role]

Status at 30 Oct 2026: no harmonised standard is cited in the OJ, no Art 7(3) act amends Annex III, and no CRA notified body was found at checks to 8 Sep 2026. Guidance C(2026) 5252 is an approved draft, not yet formally adopted.

Common mistakes

- Classifying from the marketing description. The test is objective (guidance para 142), and inconsistent documents indicate misrepresentation (para 143).
- Naming two core functionalities. A product has one for classification, and the technical documentation must state it (para 144).
- Treating an embedded important component as reclassifying the host, or an ancillary feature as declassifying it (Art 7(1); Examples 58-60).
- Keeping the register at family level when modules are sold separately. Each separately sold module is its own product (para 145).
- Assuming Module A for Class I. Art 32(2) needs a cited standard applied in full, and the wrong route can attract fines under Art 64(3) (para 146).

Template 1 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.

2 · Cybersecurity risk assessment

The cybersecurity risk assessment decides which Annex I Part I requirements apply to a product and records how each is met. Art 13(2)-(4) require it before placing on the market, documented and kept up to date during the support period. It is filed as Annex VII pt 3 of the technical documentation, with a justification for every requirement not applied.

At a glance

Item	Detail
Legal basis	Art 13(2)-(4); Annex I Part I; Annex VII pt 3; recital 55
Needed for	Deciding Part I applicability; Annex VII pt 3; the "adequate analysis and assessment of the risks" a notified body examines under Module B (Annex VIII Part II pt 3.3)
Owner	Product security officer
Approver	Head of product security; product owner co-signs residual-risk acceptance
When to create	At design, after Template 1 and before the release gate
When to update	On every trigger listed below, throughout the support period (Art 13(3))
Retention	Every version, 10 years after placing or the support period, whichever is longer (Art 13(13))
Feeds	Template 4 (Annex VII pt 3); Template 6 (Annex II pt 5 residual-risk information); Template 10 (baseline for modification tests); Template 3 (expected time in use)

How to complete

1. Pull the boundary, intended purpose and class from Template 1. Choose a method and record why; none is mandated (Commission FAQ section 4.1).

2. Draw the data-flow diagram with trust boundaries, including both ends of each RDPS link.
3. List assets in three classes, run the threat method per flow and asset, and rate each risk.
4. Select controls and trace each to the Part I requirement it serves. Fill the applicability table.
5. Record residual risk per requirement and any reliance on user information.
6. Sign off, version the document and register the update triggers.

Template

Part A: method and context

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Assessment ID and version	[RA-ID], [version], [date], [product or family]	Annex VII pt 3	RA-L2 v1.0, 31 Oct 2026, L2 family (3 SKUs)
Method and reason	[Method(s) used and why]	Commission FAQ section 4.1	BSI TR-03183-1 structure with STRIDE on the data-flow diagram
Product context	[Template 1 record reference]	Art 13(3)	CR-L2-01: lock, app, access-management cloud
Intended purpose and reasonably foreseeable use	[Purpose; foreseeable use and misuse]	Art 13(3); Art 3(23)-(24)	Home door control; guest access; foreseeable use on small-office doors
Expected time in use	[Years, from Template 3]	Art 13(3)	10 years
Operational environment	[Environment, user capability, administrator, network exposure, physical access]	Art 13(3)	Exterior door; consumer owner; home Wi-Fi; device physically reachable by passers-by

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Attacker profile	[Attackers assumed and excluded, with reasons]	Commission FAQ section 4.1	Remote opportunist; local attacker in BLE range; intruder with physical access. No capable-adversary assumption for a consumer product
Assets	[Data, functional and security assets]	BSI TR-03183-1 RH_RA.1	Data: app keys, guest codes, access log. Functional: actuator, update path. Security: root of trust, signing keys
Architecture and data flows	[Diagram reference with trust boundaries]	Annex VII pt 2(a)	DFD-L2 [version]
Component inventory	[SBOM reference and due-diligence status]	Art 13(5); recital 34	SBOM [ref]; BLE stack and TLS library reviewed
Risk rating scale	[Impact on C, I, A by likelihood]	BSI TR-03183-1 RH_RA.1.2	Impact 1-5 by likelihood from exposure and access needed
Acceptance criteria	[Per-product criteria in terms of harm to users, data and connected systems]	Guidance paras 156-163	No residual risk allowing unauthorised unlock without physical attack on the lock body

Part B: threat register

Threat ID and asset	Attack path	Rating	Requirement and control	Residual risk and treatment
T-01: replay of a captured BLE unlock (actuator)	Attacker in BLE range records and resends a command	Integrity high; likelihood medium	2(f): signed commands with nonce; stale commands rejected and logged	Low; tested by negative test NT-12
T-02: guest code used after expiry (guest codes)	Lock clock drift or offline lock keeps an expired code	Integrity high; likelihood low	2(d): expiry enforced on the lock with signed time sync	Low; Annex II pt 5 tells owners to revoke guests in the app
[T-ID: threat (asset)]	[Path]	[Impact; likelihood]	[Item: control]	[Level; treatment]

Part C: Annex I Part I applicability

One row per requirement; Part I point (1) plus the thirteen point (2) items. Cells show illustrative L2 entries.

Requirement	Applies?	How met / design measure	Evidence	Justification if not applicable
(1) Appropriate level of cybersecurity based on the risks	Yes (absolute)	Threat model and risk treatment selecting the (2) (a)-(m) controls	RA-L2 change log; DFD-L2	Cannot be disapplied
(2)(a) No known exploitable vulnerabilities	Yes	Release SBOM checked against EUVD, CVE and KEV; all available patches applied	Gate record; scan report; VEX	[ ]

Requirement	Applies?	How met / design measure	Evidence	Justification if not applicable
(2)(b) Secure by default, with reset to original state	Yes	Per-unit pairing code; no default account; factory reset to baseline	Default-config export; reset test	[ ]
(2)(c) Security updates, automatic by default where applicable, with opt-out	Yes	Signed firmware; anti-rollback; automatic updates on, postpone and opt-out in the app	Update design note; update tests	[ ]
(2)(d) Protection from unauthorised access; report possible unauthorised access	Yes	Account MFA for owners; time-limited guest keys; lockout; failed-attempt alert	Access model; negative tests	[ ]
(2)(e) Confidentiality of stored, transmitted and processed data	Yes	TLS 1.3 to the cloud; encrypted BLE session; keys in secure storage	Cryptographic inventory; downgrade test	[ ]
(2)(f) Integrity of data, commands, programs and configuration; report corruption	Yes	Verified boot; signed commands with nonce; integrity alert	Boot-chain test; replay test	[ ]
(2)(g) Data minimisation	Yes	Access log kept [n] days; telemetry off by default	Data inventory; retention schedule	[ ]

Requirement	Applies?	How met / design measure	Evidence	Justification if not applicable
(2)(h) Availability of essential functions, also after an incident; DoS mitigation	Yes	Keypad and BLE unlock work without the cloud; BLE rate limiting	Cloud outage test; stress report	[ ]
(2)(i) Minimise impact on other devices and networks	Yes	Emitters limited to cloud link, update check and NTP; retry back-off	Emitter inventory; port scan	[ ]
(2)(j) Limit attack surfaces, including external interfaces	Yes	BLE advertising only during pairing; debug ports locked by fuse	Interface inventory; debugger attach test	[ ]
(2)(k) Exploitation mitigation	Yes	Hardened build flags; memory protection unit separation; input validation	Compiler-flag evidence; fuzzing report	[ ]
(2)(l) Logging of relevant internal activity, with user opt-out	Yes	Unlock, key issue, failed-auth and update events logged; opt-out documented with events that persist	Event catalogue; opt-out test	[ ]
(2)(m) Secure erase; secure transfer where possible	Erase yes; transfer no	Factory reset deletes keys, log and cloud binding	Write-erase-read test	Transfer: no transferable data; the new owner re-creates the access list. Erase steps in Annex II pt 8(d)

Part D: Annex I Part II

Requirement	Applies?	How applied	Evidence
Annex I Part II points 1-8 (vulnerability handling)	Yes; all apply (no risk-assessment chapeau; pt 2 is "in relation to the risks posed")	[Statement of how each process is applied, as Art 13(3) requires]	SBOM, CVD policy (Template 7), update design note, reporting runbook (Template 8)

Part E: residual-risk acceptance

Field	What to enter	Basis
Decision right	[Role accepting residual risk; it must be named]	Governance
Criteria met	[Which acceptance criterion each residual risk meets]	Guidance paras 156-163
Other means relied on	[Intended-use limits or user information, with Annex II pt 5 reference]	Recital 55
Signature	[Name], [role], [date]	Art 13(3)

Cost, commercial strategy and internal risk tolerance are not valid reasons (guidance paras 156-163). Risk cannot be shifted to users to cover a design shortcoming; an unaddressable risk means changing the design, functionality or intended purpose.

Part F: update triggers

- [ ] Security-relevant release, including changed interfaces, dependencies, update path or RDPS boundary
- [ ] Newly known vulnerability in the product or a component
- [ ] Newly known threat or attack technique for the product class
- [ ] New findings from security tests, reviews or penetration tests (Annex I Part II pt 3)
- [ ] Substantial-modification assessment at the release gate (Template 10)

Each update is a new version with a change log. Keep all versions placed on the market (Art 13(13)).

Common mistakes

- Marking (2)(a), (b), (d) or (l) not applicable without strong reasons. Drafting bodies treat them as near-universal.
- Writing "accepted, business decision" as a residual-risk treatment. It fails; name the criterion, the control and the re-test trigger.
- Leaving the manufacturer-built backend out because "it is cloud". Assess both ends of each RDPS boundary.
- Treating scanner hits as risk. Apply reachability and record VEX justifications.
- Updating on a calendar only. Wire the triggers into PSIRT and release processes.

Template 2 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.

3 · Support period determination

The support period determination records how long the manufacturer will handle vulnerabilities for a product, and why. Art 13(8) requires at least five years unless the product is expected to be in use for less, and Annex VII pt 4 requires the information used to set it. Complete it before placing on the market and file it with the technical documentation.

At a glance

Item	Detail
Legal basis	Art 13(8); Art 13(9)-(11); Art 13(19); Annex VII pt 4; Annex II pt 7
Needed for	Annex VII pt 4; the end date shown at purchase; the period over which Annex I Part II applies
Owner	Product manager
Approver	Compliance lead, with legal counsel
When to create	At design, once intended purpose and expected time in use are agreed (Template 1, Template 2)
When to update	For each new variant and each substantially modified version; when expected-use evidence changes
Retention	10 years after placing or the support period, whichever is longer (Art 13(13))
Feeds	Template 4 (Annex VII pt 4); Template 6 (Annex II pt 7 end date); Template 2 (expected time in use); Template 9 (supplier support commitments)

How to complete

1. State the expected time in use from Template 1 and Template 2.
2. Gather evidence for each Art 13(8) factor and enter it in the evidence table.
3. Set the period. Treat five years as a floor, not a default (guidance paras 125-128).
4. Convert the period to an end month and year per variant and, for software, per substantially modified version.

5. Record how the end date is shown at purchase and how users are told when support ends.
6. Enter each version in the version-support register and obtain sign-off.

Template

Part A: determination

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Determination ID and version	[SP-ID], [version], [date]	Annex VII pt 4	SP-L2-01 v1.0, 31 Oct 2026
Product and variants	[Family, variants, SKUs; Template 1 reference]	Art 13(8)	L2 Smart Lock, 3 SKUs; CR-L2-01
Expected time in use	[Years and the reason]	Art 13(8)	10 years: a door lock stays fitted until the door or owner changes
Reasonable user expectations	[What buyers expect, with evidence]	Art 13(8)	Buyers expect a lock to outlast a phone; see evidence table
Nature of the product	[Hardware, software or both; long-lived category?]	Art 13(8); recital 60	Hardware with firmware, app and cloud; physical security function
Relevant Union law	[Other acts setting lifetimes or duties]	Art 13(8)	[None identified]
Shorter than five years?	[Only if expected use is shorter; give the evidence]	Art 13(8)	No
Declared support period	[Years]	Art 13(8)	10 years
End month and year	[Per variant, or per batch for hardware placed unit by unit]	Art 13(19); Annex II pt 7	First batch placed under the CRA [Dec 2027]: end [Dec 2037]

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Update availability	[Each update kept available 10 years or the rest of the period, whichever is longer]	Art 13(9)	Signed-artefact repository budgeted for 10 years after last release
Latest-version-only patching	[Yes or no; free upgrade path without added hardware or software cost]	Art 13(10)	No; all firmware versions in support receive fixes
Archives of old versions	[Public archive with risk warnings, if offered]	Art 13(11)	Archive page with warning text
Sign-off	[Name], [role], [date]	Governance	[Name], Product manager; [Name], Compliance lead

The Art 13(8) factors follow the order of the OJ text: expected time in use, reasonable user expectations, nature of the product, relevant Union law; the rest are optional. No delegated act on minimum periods exists as of 30 Oct 2026.

Part B: expected-use evidence

Evidence source	What it shows	Factor	Example: L2 Smart Lock (illustrative)
Installed-base and field data	Age of units still connected	Expected time in use	[% of earlier-generation locks active after 7 years]
Warranty, returns and replacement data	When users replace the product	Expected time in use	[Median replacement age]
Comparable products	Periods declared for similar products by other manufacturers	Optional factor (Art 13(8)); also informs reasonable user expectations	[Competitor periods, with source]
Customer research and complaints	What buyers assume about support	Reasonable user expectations	[Survey reference]

Evidence source	What it shows	Factor	Example: L2 Smart Lock (illustrative)
Product category	Whether the category is typically used for longer	Nature of the product; recital 60	Long-lived home hardware
Supplier support commitments	Whether chipset, OS and library support covers the period; availability of the operating environment	Optional factors (Art 13(8)): support periods of integrated core components; availability of the operating environment	[BLE stack and MCU vendor commitments; Template 9]
Other Union law	Lifetimes or duties set elsewhere	Relevant Union law	[None identified]

Part C: decision and publication

Field	What to enter	Basis
Where shown at purchase	[Product, packaging or digital means; retail listing]	Art 13(19)
Annex II entry	[Annex II pt 7 text and URL; Template 6]	Annex II pt 7
End-of-support notice	[In-product or in-app notice where technically feasible; content: date, risk of continued use, upgrade path]	Art 13(19)
Annex VII filing	[Location of this record in the technical documentation; Template 4]	Annex VII pt 4

Part D: version-support register

Each substantially modified version carries its own declared period. A modification does not reset or extend an existing period (guidance paras 132-135). For standalone software, the product is placed at its first offering; later versions keep that placing date unless they are a substantial modification (guidance paras 13-15, Example 2). Record every version and whether it is a new placing.

Version	New placing?	Placing date	Declared end (month, year)	Shown at purchase	Update channel	Migration path	Legacy-version owner
L2 firmware [x.y] (illustrative)	Yes (first placing)	[Dec 2027]	[Dec 2037]	Packaging and app store listing	Automatic OTA	Free OTA to latest	Product manager, HBS
[Version]	[Yes/No]	[Date]	[Month, year]	[Where]	[Channel]	[Path]	[Role]

Common mistakes

- Declaring five years by default. It "operates only as a safeguard" and is not the default (guidance paras 125-128).
- No version record for software, so nobody knows which versions get fixes or which are new placings. Keep the version-support register.
- Showing a duration instead of an end date. Art 13(19) requires at least the month and the year at purchase.
- Assuming a substantial modification extends the period for earlier versions. It does not (paras 132-135).
- Setting a period that component suppliers cannot support. Secure supplier commitments first (Template 9).

Template 3 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.

4 · Technical documentation index

The technical documentation index is the first page of a product's Annex VII file. It lists every required content item, the artefact that satisfies it, its owner, where it is kept and its status. Art 31 requires the file before placing on the market; keep the index in the system of record and update it at every release gate.

At a glance

Item	Detail
Legal basis	Art 31; Annex VII pts 1-8; Art 13(12)-(13); Art 13(22)
Needed for	Every conformity route; any market surveillance request; the notified-body application under Module B or H
Owner	Compliance lead
Approver	Head of product security
When to create	At project start; populate as artefacts are produced
When to update	At each release gate, each placing of a new version and each substantial modification
Retention	10 years after placing or the support period, whichever is longer (Art 13(13))
Feeds	Draws on Templates 1-3 and 5-9; supports Template 10

How to complete

1. Fill the control block: product, variants, file version, retention date and language.
2. For each Annex VII row, name the artefact, owner, location and version.
3. Link every artefact to a controlled record in the system of record, never to a mailbox or personal drive.
4. If one file covers a family, complete the variant list.
5. Mark status per row and close gaps before the release gate.
6. Freeze a copy of the index with each placing on the market.

Template

Part A: control block

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
File ID and version	[TF-ID], [version], [date]	Art 31	TF-L2 v1.0
Product and variants	[Family; variant list in Part C]	Guidance paras 174-177	L2 Smart Lock, 3 SKUs
Conformity route	[From Template 1]	Art 32	Module B+C (planned)
Retention end	[10 years after last placing, or end of support period, whichever is later]	Art 13(13)	[Date]
Working language	[Working language; for a notified-body route, an official language of the body's Member State or one it accepts; translation plan for authorities]	Art 31(4); Art 13(22)	English, accepted by the notified body; translation on request
System of record	[GRC platform, document-management system or compliance tool with audit trail]	Evidence governance	[Tool name]
Legacy design relief	[Yes or no; scope]	Guidance pts 37-39	[Yes, for design phases before 11 Dec 2027]

Part B: Annex VII index

Document names show illustrative L2 entries. Point 1 rows 1(a)-1(d) follow the lettering of Annex VII point 1 in the OJ text.

Annex VII point	Content required	Document / artefact	Owner	Location (system of record)	Version	Status
1(a)	General description, including intended purpose; core functionality (guidance para 144)	Classification record CR-L2-01 (Template 1); product definition record	Product security officer	[Path]	[v]	[Draft / Approved / Missing]
1(b)	Versions of software affecting compliance with essential requirements	Release manifest per firmware and app version	Release manager	[Path]	[v]	[ ]
1(c)	For hardware: photographs or illustrations of external features, marking and internal layout	Photo set PH-L2	Hardware lead	[Path]	[v]	[ ]
1(d)	User information and instructions under Annex II	Annex II document (Template 6) and its URL	Technical writing	[URL]	[v]	[ ]
2(a)	Design and development: drawings and system architecture showing how software components build on or feed into each other	Architecture document; data-flow diagram DFD-L2	Engineering lead	[Path]	[v]	[ ]
2(b)	Vulnerability handling: SBOM, CVD policy, evidence of the reporting contact address, secure update distribution	SBOM per release; CVD policy (Template 7); security.txt capture; update design note	PSIRT lead	[Path]	[v]	[ ]
2(c)	Production and monitoring processes, with validation	Build, signing and release process; gate records	Quality lead	[Path]	[v]	[ ]

Annex VII point	Content required	Document / artefact	Owner	Location (system of record)	Version	Status
3	Cybersecurity risk assessment under Art 13, with Part I applicability and justifications	RA-L2 (Template 2) with change log	Product security officer	[Path]	[v]	[ ]
4	Information used to determine the support period under Art 13(8)	SP-L2-01 (Template 3); version-support register	Product manager	[Path]	[v]	[ ]
5	Harmonised standards, common specifications or certification schemes applied in full or in part; otherwise the solutions adopted	Standards statement, with drafts labelled "draft"	Compliance lead	[Path]	[v]	[ ]
6	Test reports on the product against Annex I Part I	Test reports indexed by requirement	Test lead	[Path]	[v]	[ ]
6	Test reports on vulnerability-handling processes against Annex I Part II	Process audit and PSIRT test records	PSIRT lead	[Path]	[v]	[ ]
7	Copy of the EU declaration of conformity	Declaration (Template 5)	Compliance lead	[Path]	[v]	[ ]
8	SBOM, where applicable, supplied on a market surveillance authority's reasoned request	SBOM annex per version	SBOM owner	[Path]	[v]	[ ]

No harmonised standard is cited in the OJ as of 30 Oct 2026, so point 5 will describe the solutions adopted.

Part C: family variant list

One file may cover a family sharing architecture, security-relevant design, intended purpose and risks (guidance pts 174-177).

Variant	Model and SKU	Differences from reference variant	Affected risk-assessment rows	Separate evidence	Declared end of support
Reference	L2-STD (illustrative)	None	None	Full set	[Month, year]
[Variant]	[SKU]	[Interface, stack, update or connectivity differences]	[e.g. 2(i), 2(j)]	[Tests]	[Month, year]

A different update mechanism or remote connectivity usually means a new family, not a variant.

Part D: obligations around the file

Obligation	What to record	Basis
File complete before placing	Date the file was frozen for this version	Art 31; Art 13(12)
Kept current	Update log through the support period	Art 31
Retention	Retention end date per placing	Art 13(13)
Reasoned request	Named contact; translation route into a language the authority can easily understand	Art 13(22)
Legacy relief	Design phases where test evidence is replaced by the risk assessment; Part II evidence still held	Guidance pts 37-39
Publication	Not owed to customers or the public, except FOSS self-attesting under Art 32(5)	Commission FAQ 6.6

The simplified Annex VII format for micro and small enterprises (Art 33(5)) depends on an implementing act. None is adopted, drafted or scheduled as of 30 Oct 2026, so build the full file.

Common mistakes

- Assembling evidence by hand when asked. Emit gate records, SBOM hashes and test results at release and index them here.
- Keeping the file on a shared drive. It needs controlled versions, access management and an audit trail.

- Overwriting the file for a new version. Each placing freezes a set; earlier versions stay retained.
- Calling products a family because they share a brand. An engineer must be able to name the shared security architecture document.
- Leaving the manufacturer-built backend out of points 2(a) and 3.

Template 4 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.

5 · EU declaration of conformity

The EU declaration of conformity is the manufacturer's signed statement that a product meets the CRA essential requirements. Art 28 and Annex V set its content, and Art 13(12) requires it after the technical documentation and the Art 32 procedure, before placing on the market. File the signed original in the technical documentation (Annex VII pt 7) and publish it at the address given in the user information (Annex II pt 6).

At a glance

Item	Detail
Legal basis	Art 28; Annex V (full form); Annex VI (simplified form); Art 13(12), 13(13), 13(20); Arts 29-30 (CE marking)
Needed for	Every product with digital elements placed on the EU market, whatever its class or conformity route
Owner	Compliance lead
Approver	Executive sponsor or a delegate named in a signed instrument signs. By drawing up the declaration, the manufacturer assumes responsibility for compliance (Art 28(4))
When to create	After the technical documentation is complete and the Art 32 assessment is positive; before CE marking and placing on the market (Art 13(12); Commission FAQ 6.7)
When to update	"Updated as appropriate" (Art 28): new standards applied, new certificate, new variants, changed manufacturer details. A substantial modification is a new placing and "might need a new declaration" (FAQ 6.8; guidance pt 116)
Retention	10 years after placing or the support period, whichever is longer (Art 13(13)); keep superseded versions
Feeds	Template 4, Annex VII pt 7; Template 6, Annex II pt 6; Template 10, re-declaration after a substantial modification. Fed by Template 1 (class and route)

How to complete

1. Take the class and conformity route from Template 1. A Class I product without a fully applied OJ-cited standard, common specification or scheme must use Module B+C or H (Art 32(2)).
2. Confirm the technical documentation (Template 4) and the conformity assessment are complete and positive. Do not sign before that (FAQ 6.7).
3. Fill the Annex V field table. Use one declaration per product, or one per family that clearly identifies the variants (guidance pts 174-177).
4. Adapt the full wording below and translate it into the languages required by the Member States of sale (Art 28(2)).
5. Have the authorised signatory sign. Log the declaration ID, signatory and authority instrument in the evidence index.
6. Publish the full declaration at a stable URL. Print the Annex VI text with that exact address on packaging or in-app screens (Art 13(20)).
7. Affix the CE marking under the rules below and file a copy in the technical file.

Template

Annex V fields

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Declaration ID and version	Internal reference, version number, date of issue. Control field, not an Annex V point	Art 28 ("updated as appropriate")	DoC-HBS-L2-[001], version 1, [date]
1. Product identification	Name, type and information enabling unique identification: model, SKUs, hardware revision, software or firmware versions	Annex V pt 1	L2 Smart Lock, type L2; 3 SKUs L2-STD, L2-KEY, L2-RTF; hardware rev [x]; firmware [x.y] and later; companion app [x.y]
2. Manufacturer	Name and address of the manufacturer, or of its authorised representative	Annex V pt 2	Example Group [legal entity], Home & Building Solutions, [street], [postcode] [city], Germany

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
3. Sole responsibility	Fixed statement, see wording below	Annex V pt 3 (OJ wording: "provider")	Statement as drafted
4. Object of the declaration	Description allowing traceability; a photograph is optional	Annex V pt 4	Battery-powered smart door lock with app keys and guest access. Uses the Example Group access-management cloud as remote data processing. Photograph [ref]
5. Statement of conformity	Conformity with the relevant Union harmonisation legislation, listing each act covered	Annex V pt 5; Art 28(3)	Regulation (EU) 2024/2847; [other applicable Union act, e.g. radio equipment legislation, with OJ reference]
6. Standards and specifications	Harmonised standards, common specifications or cybersecurity certifications used, with versions; state "in part" where partial	Annex V pt 6	No CRA harmonised standard cited in the OJ as at 30 Oct 2026. Other specifications applied: [list, each labelled "draft" where it is a draft]
7. Notified body	Where applicable: body name and number, procedure performed, certificate identification	Annex V pt 7	[Notified body name], number [xxxx]; EU-type examination (Module B), certificate [ID] of [date]; conformity to type (Module C). No CRA notified body was designated at checks to 8 Sep 2026

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
8. Additional information and signature	Variants covered, other useful facts; "signed for and on behalf of", place and date, name, function, signature	Annex V pt 8	Variants: L2-STD, L2-KEY, L2-RTF. Support period ends [month year] (10 years). Signed for Example Group [legal entity], [city], [date], [name], [function]

Full declaration (Annex V) wording

The block below is a drafting model that follows the Annex V points. The point 3 statement quotes the OJ text.

```
EU DECLARATION OF CONFORMITY
No. [declaration ID]   Version [n]   [date of issue]

1. Product with digital elements: [product name], type [type or model],
   [SKUs or variants], hardware revision [x], software/firmware version
[x.y],
   [other information enabling unique identification].

2. Name and address of the manufacturer [or its authorised representative]:
   [legal name], [postal address], [country].

3. This declaration of conformity is issued under the sole responsibility
   of the provider.

4. Object of the declaration: [description allowing traceability].
   [Optional: photograph of the product.]

5. The object of the declaration described above is in conformity with the
   relevant Union harmonisation legislation:
   - Regulation (EU) 2024/2847 (Cyber Resilience Act)
   - [other Union act, with OJ reference, where this declaration covers it]

6. References to the harmonised standards, common specifications or
   cybersecurity certifications used, in relation to which conformity
   is declared:
   - [reference, version, date; applied in full / in part]
   [or: None.]
```

```
7. Where applicable: the notified body [name] (number [xxxx]) performed
   [EU-type examination (Module B) / approval of the quality system (Module
H)]
   and issued the certificate [certificate identification], dated [date].

8. Additional information: [variants covered; other information].

Signed for and on behalf of: [manufacturer legal name]
[place of issue], [date of issue]
[name], [function]
[signature]
```

Point 3 quotes Annex V of the Official Journal text, which confirms "provider" in English and in the German ("Anbieter") and French ("fournisseur") versions. You may add the manufacturer's legal name after it; do not replace the statutory word.

Simplified declaration (Annex VI) wording

The opening is the Annex VI wording as quoted in the KB. The address must be "the exact internet address" of the full declaration (Art 13(20)).

```
Hereby, [manufacturer legal name] declares that the product with digital
elements type [product type] is in compliance with Regulation (EU) 2024/2847.
The full text of the EU declaration of conformity is available at the
following internet address:
[exact internet address of the full declaration]
```

Example: L2 Smart Lock (illustrative)

```
Hereby, Example Group [legal entity] declares that the product with digital
elements type L2 Smart Lock (L2-STD, L2-KEY, L2-RTF) is in compliance with
Regulation (EU) 2024/2847.
The full text of the EU declaration of conformity is available at the
following internet address:
https://www.example.com/security/l2/declaration/
```

CE marking rules

Rule	What to do	Basis	Example: L2 Smart Lock (illustrative)
Hardware placement	Visibly, legibly and indelibly on the product; else on the packaging and the declaration. May be under 5 mm where the product's nature warrants	Art 30(1)-(2)	On the lock's rear housing plate and on the packaging
Software placement	On the declaration or on the accompanying website, in a section consumers can reach directly. No authority has addressed app-store listings	Art 30(1)	Companion app: CE marking on the declaration and on the L2 security page
Timing	Before placing on the market, and only after a positive conformity assessment	Art 13(12); FAQ 6.7	Not before the Module B certificate is issued
Notified body number	Follows the CE marking only where the body is involved under Module H	Art 30(4)	Module B+C: CE marking alone. If Module H is chosen instead: CE followed by [body number]
Other CE legislation	One marking indicates compliance with all applicable CE legislation	Art 30(5)	One CE marking covers the CRA and [other act]
Future labels	Implementing acts on pictograms or support-period marks; none adopted	Art 30(6)	Watch item

Languages, scope and updates

Topic	Rule	Basis
Languages	The languages required by each Member State where the product is made available	Art 28(2)

Topic	Rule	Basis
One per product	Tied to the individual product rather than the type; a family declaration must clearly identify the variants	Art 28; FAQ 6.8; guidance pts 174-177
Updates	Keep it "updated as appropriate"; a new version after a substantial modification "might need a new declaration"	Art 28; FAQ 6.8
Several Union acts	One single declaration must cover every Union act that requires one, identifying each act and its OJ publication reference	Art 28(3)
Requests	Market surveillance may request the declaration and all conformity documentation on reasoned request	Art 13(22)

Guidance C(2026) 5252 is an approved draft; no formal adoption or OJ publication was found as at 30 Oct 2026.

Common mistakes

- Signing the declaration or affixing the CE marking before a positive assessment. A Class I product cannot self-declare under Module A until a cited standard is applied in full (Art 32(2); FAQ 6.7).
- Adding the notified body number beside the CE marking under Module B+C. It belongs there only under Module H (Art 30(4)).
- No controlled signing authority, so declarations are signed by whoever is asked. Use a signing instrument, a pre-signature checklist and a counter-signature.
- An Annex VI text without the exact internet address, or a declaration URL that breaks during the retention period.
- Treating RED certificates or EN 18031 assessments as CRA conformity. Art 69(1) keeps them valid until 11 Jun 2028; they evidence RED compliance, not CRA conformity (inference).

Template 5 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.

6 · User information and instructions

The user information document carries the security facts a user needs to buy, commission, run and retire the product safely. Art 13(18) and Annex II require the listed information to accompany every product "at minimum" (Annex II), "in paper or electronic form" (Art 13(18)). Write one versioned document per product or family, publish it at a stable URL, and file a copy in the technical documentation (Annex VII pt 1).

At a glance

Item	Detail
Legal basis	Art 13(18); Annex II pts 1-9; Art 13(16) (manufacturer contact), 13(17) (single point of contact), 13(19) (end date at purchase), 13(11) (archive warnings)
Needed for	Every product with digital elements, whatever its class. No Commission or ENISA template exists
Owner	Technical writing lead, with the product security officer
Approver	Compliance lead
When to create	Before placing on the market; freeze the text per version at the release gate
When to update	Each new version or substantial modification; any change of contact, support end date, update method or decommissioning steps. Publish a new version page and keep the old one
Retention	Available for 10 years or the support period, whichever is longer; information provided online stays online (Art 13(18))
Feeds	Template 4, Annex VII pt 1; Template 5, Annex II pt 6 carries the declaration address; Template 7, pt 2 carries the CVD contact; Template 3, pt 7 carries the end date; Template 8, user-notice channels

How to complete

1. Pull intended purpose, foreseeable misuse and residual risks from the product definition record and Template 2.
2. Take the support end month and year that applies to each version from Template 3, and the contact and policy URL from Template 7.
3. Fill one row per Annex II point below. Write concrete steps, not disclaimers.
4. Publish at a versioned URL such as `/security/<product>/<version>/` with a `latest` alias. Never delete a version page while its retention runs.
5. Place each item where the table says: manual, website, packaging, product label or app.
6. Check the text against the shipped behaviour, especially the automatic-update opt-out (pt 8(e)).
7. Use language easily understood by users and by market surveillance authorities in the Member States of sale.

Template

Annex II point	What to write	Where it appears	Example: L2 Smart Lock (illustrative)
1. Manufacturer	Manufacturer name; postal address; email or other digital contact; website where available. Art 13(16) also requires identity and contact on the product, packaging or accompanying document	Product label or packaging; manual; website	Example Group [legal entity], Home & Building Solutions, [street], [postcode] [city], Germany; support@example.com; www.example.com
2. Vulnerability contact	Single point of contact for vulnerability reports and where the CVD policy is found. Same contact as security.txt. Not limited to automated tools (Art 13(17))	Manual; website; app (Settings > About)	psirt@example.com; web form www.example.com/security/report; phone [+49 number], staffed [hours]. Policy: www.example.com/security/cvd-policy

Annex II point	What to write	Where it appears	Example: L2 Smart Lock (illustrative)
3. Product identification	Name, type and information enabling unique identification	Product label; packaging; manual; app	L2 Smart Lock, type L2, SKUs L2-STD, L2-KEY, L2-RTF; serial on rear plate; firmware version in app (Settings > About)
4. Intended purpose and security	Intended purpose; the security environment the manufacturer assumes; essential functionalities; security properties	Manual; website	Residential front-door lock for consumers. Assumes a home Wi-Fi network, a supported smartphone and the Example Group access-management cloud. Functions: lock, unlock, app keys, guest access, access log. Properties: per-device credentials, signed firmware, encrypted app and cloud traffic
5. Use and misuse risks	Known or foreseeable circumstances of use or misuse that may lead to significant cybersecurity risks, each with the compensating measure	Manual; website	Guest keys shared without an expiry date: set an end date for every guest key. Phone with an outdated operating system: keep the phone updated. Automatic updates turned off: unpatched locks can be opened by known attacks
6. Declaration address	Internet address of the EU declaration of conformity, where applicable	Manual; packaging (with Annex VI text); website	www.example.com/security/l2/declaration/
7. Support type and end date	Type of technical security support and the end date of the support period. Art 13(19) requires at least the month and year at the time of purchase	Packaging; point of sale and web shop; manual; website; app	Free security updates installed automatically over the air until [month year] (10-year support period from first placing)
8(a). Secure use	Measures at initial commissioning and throughout the lifetime	Quick-start guide; manual; app onboarding	Install the latest firmware during set-up; set the owner account with two-step sign-in; review the access log monthly; revoke unused keys
8(b). Changes and data security	How changes to the product can affect the security of data	Manual; website	Linking a third-party smart home bridge or adding users widens who can unlock. A factory reset removes all keys and pairings

Annex II point	What to write	Where it appears	Example: L2 Smart Lock (illustrative)
8(c). Installing updates	How security-relevant updates can be installed	Manual; app; website	Updates install automatically overnight. Manual check: app > Settings > Firmware > Check now
8(d). Decommissioning	Secure decommissioning, including secure removal of user data	Manual; website; app	Remove the lock from your account in the app, then hold the reset button for [10] seconds. This erases keys, logs and the cloud binding
8(e). Turning off automatic updates	How to turn off default automatic installation of security updates (Annex I Part I pt 2(c)), with the risk of doing so	Manual; app; website	App > Settings > Updates > Automatic security updates: Off. Postpone allows up to [n] days. Without updates the lock stays exposed to fixed vulnerabilities
8(f). Integration	For products intended for integration: what integrators need to meet Annex I and Annex VII	Integrator guide; website	Not applicable: L2 is a finished product. If [the integration API] is offered to integrators, document it here
9. SBOM access	Where users can access the SBOM. Optional: include only if the manufacturer chooses to offer it	Website, if offered	Not offered to users. The SBOM is held in the technical file for market surveillance requests (Annex VII pt 8)

Publication checklist

Item	Rule	Basis
Form	Paper or electronic; a versioned documentation URL satisfies it	Art 13(18)
Availability	10 years or the support period, whichever is longer; online copies kept online	Art 13(18)
End date at purchase	At least the month and year, on the product, packaging or digitally at the time of purchase; end-of-support notice in the product where feasible	Art 13(19)

Item	Rule	Basis
Archive warnings	Public archives of old versions only with clear risk warnings	Art 13(11)
One page	The versioned security page can host the CE marking for software, the declaration, the advisory index and archive warnings	Art 30(1); Annex VI; Annex II

Common mistakes

- Point 5 written as a disclaimer. Write concrete conditions and compensating measures, carried over from residual risks in the risk assessment.
- A point 2 contact that differs from security.txt, or a chatbot as the only channel (Art 13(17)).
- No end month and year at the point of sale, or, for software, no record of which declared end date applies to each version (Art 13(19)).
- Point 8(e) text that does not match the real opt-out, postponement and notification behaviour.
- A logging opt-out that silently disables security events without saying so in the user information.

Template 6 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.

7 · Vulnerability disclosure policy

The vulnerability disclosure policy tells researchers, customers and suppliers how to report a vulnerability and what the manufacturer will do with it. Annex I Part II pt 5 requires a coordinated vulnerability disclosure (CVD) policy that is "put in place and enforce[d]", and pt 6 requires a reporting contact address. Publish it at the URL named in security.txt and Annex II pt 2, and file it in the technical documentation (Annex VII pt 2(b)).

At a glance

Item	Detail
Legal basis	Annex I Part II pts 2, 4, 5, 6, 7, 8; Art 13(6) (upstream reporting), 13(17) (non-automated contact); Annex II pt 2; Annex VII pt 2(b); Recital 76
Needed for	Every product. Part II applies from 11 Dec 2027, but Art 14 reporting has applied since 11 Sep 2026, so the intake must work now
Owner	PSIRT lead
Approver	Compliance lead, with legal for the safe harbour wording
When to create	Before placing on the market; now for products already in the field
When to update	Review yearly. Update on any change of contact, key, coordinator CSIRT or targets. Check security.txt quarterly and renew before Expires
Retention	Policy versions, case files, advisories and upstream reports: 10 years or the support period, whichever is longer (Art 13(13))
Feeds	Template 4, Annex VII pt 2(b); Template 6, Annex II pt 2; Template 8, the exploitation determination starts the Art 14 clock; Template 9, supplier notification duties

How to complete

1. Fill the field table for each product family: scope, channels, targets, coordinator CSIRT.
2. Set internal targets at or inside the reference figures shown. None of them is a legal deadline.
3. Adapt the policy text below. Decide with legal whether to include the safe harbour section.
4. Publish the policy at a stable URL and link it from the home page, security.txt and Annex II pt 2.
5. Publish security.txt at `/.well-known/security.txt` over HTTPS and sign it with the PSIRT OpenPGP key.
6. Staff every channel, monitor them daily and measure acknowledgement and response times.

Template

Policy fields

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Scope	Products, versions, companion apps, remote data processing and third-party components covered	Part II pt 6 ("as well as in third-party components")	All L2 SKUs and firmware versions in the field, including versions past end of support; L2 app; access-management cloud
Reporting contact	A contact address for reporting vulnerabilities; same as Annex II pt 2	Part II pt 6; Annex II pt 2	psirt@example.com
Web form	Allows anonymous submission; no third-party scripts or tracking	Recital 76; BSI TR-03183-3 (non-binding)	www.example.com/security/report
Non-automated channel	A monitored mailbox or phone line beside any automated tool	Art 13(17)	[+49 phone number], staffed [hours]

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Encryption	OpenPGP key for confidential reports	BSI TR-03183-3; ENISA kit (recommended)	www.example.com/security/psirt-pgp.asc
Acknowledgement target	No legal figure. BSI: non-automated response in 5 working days. Draft prEN 40000-1-3 reportedly caps it at 7 calendar days (second-hand, unpublished)	Part II pt 5	[5] working days
Detailed feedback target	No legal figure. BSI: 10 working days	Part II pt 5	[10] working days
Remediation	"Without delay" and "in relation to the risks posed". Not quantified in law; set internal targets by severity	Part II pt 2	[Critical: n days; High: n days; Medium: n days]
Disclosure timeline	Publish fixed vulnerabilities once an update is available; delay only "in duly justified cases". BSI default of 90 days, extendable once, is not law. Add an accelerated path for actively exploited vulnerabilities	Part II pt 4	[90] days or on fix release, whichever is first; exploited cases [accelerated]
Advisories	Human-readable advisory plus CSAF 2.0 with CVE and EUVD IDs, affected and fixed versions, severity, impact, remediation	Part II pt 4	Advisory index www.example.com/security/advisories

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Update delivery	Secure distribution; automatic where applicable; free of charge with advisory messages	Part II pts 7, 8	Signed over-the-air updates, free, with an in-app advisory
Upstream reporting	Report component vulnerabilities to the maintainer; share fixes where appropriate in machine-readable form	Art 13(6)	Report via the maintainer's CVD channel; record each action in the case file
Coordinator CSIRT	Name the CSIRT the manufacturer reports to and offer the anonymous route through it	Recital 76; Art 14(7)	Germany's coordinator CSIRT ([name and URL from ENISA's list of 4 Sep 2026])
Safe harbour	Optional. Legal decides scope and wording	ENISA kit section	Included, reviewed by legal [date]

Policy text

```
[MANUFACTURER] VULNERABILITY DISCLOSURE POLICY
Version [n], [date]. Owner: [PSIRT lead role].

1. Our commitment
We want to hear about vulnerabilities in our products. We investigate every
report, fix confirmed vulnerabilities without delay in relation to the risk
they pose, and provide security updates free of charge for the support
period.

2. Scope
This policy covers [products, versions, companion apps and online services],
including third-party components they contain. Out of scope: [e.g. corporate
IT systems; report those to [csirt contact]].

3. How to report
- Email: [psirt@domain] (encrypt with our key at [URL] if possible)
- Web form: [URL] (anonymous reports accepted)
```

- Phone: [number], [hours]
You may also report anonymously through [coordinator CSIRT name, URL].

4. Testing rules
Test only devices and accounts you own or are authorised to use. Do not access,
change or delete other people's data. Do not degrade our services. Stop and report as soon as you have shown the issue.

5. What to include
Product, model and version; description and impact; steps to reproduce or proof of concept; whether you believe it is being exploited; how to contact you.

6. What to expect
Acknowledgement within [n] working days. Detailed feedback within [n] working days. Status updates at least every [n] days until resolution.

7. Safe harbour [optional, confirm with legal]
If you act in good faith and follow this policy, we will not pursue legal action against you for your research, and we will say so if a third party asks. [Limits and jurisdictions.]

8. Disclosure
We publish an advisory once a fix is available, normally within [n] days of your report. We may delay publication only where duly justified, until users have been able to update. Actively exploited vulnerabilities follow an accelerated timeline. We agree the date with you before publishing.

9. Third-party components and coordination
We report vulnerabilities in components to their maintainers and share fixes where appropriate. Where needed we coordinate with [coordinator CSIRT].

10. Recognition
With your consent we credit you in the advisory and at [hall-of-fame URL].

11. Data protection
We use your contact details only to handle your report. See [privacy notice URL].

security.txt

Field	Status	Rule	Basis
Contact	Mandatory	One line per channel, preferred method first	RFC 9116; ENISA kit section 3.1
Expires	Mandatory	At most 12 months ahead; renew before it lapses	RFC 9116; ENISA profile
Policy	Recommended	URL of this policy	ENISA profile
Preferred-Languages	Recommended	Languages the PSIRT reads	ENISA profile
Canonical	Recommended	The file's own HTTPS URL	ENISA profile
Encryption	Optional, recommended	URL of the PSIRT OpenPGP key	ENISA profile
Acknowledgments, CSAF	Optional	Hall of fame; CSAF provider metadata	BSI TR-03183-3 section 4.2.8

Example: L2 Smart Lock (illustrative). Sign the file with the PSIRT key.

```
# https://www.example.com/.well-known/security.txt
Contact: mailto:psirt@example.com
Contact: https://www.example.com/security/report
Contact: tel:+49-[number]
Expires: 2027-10-30T23:59:59.000Z
Encryption: https://www.example.com/security/psirt-pgp.asc
Preferred-Languages: en, de
Canonical: https://www.example.com/.well-known/security.txt
Policy: https://www.example.com/security/cvd-policy
Acknowledgments: https://www.example.com/security/hall-of-fame
CSAF: https://www.example.com/.well-known/csaf/provider-metadata.json
```

The ENISA SME Vulnerability Kit cited here is an October 2026 consultation draft, and prEN 40000-1-3 is unpublished.

Common mistakes

- An expired security.txt. Expired contacts head ENISA's common-mistakes list.
- A published policy nobody staffs or monitors.
- An intake that refuses reports about third-party components (Part II pt 6).

- BSI or draft-standard figures written into the policy as legal deadlines, or targets that are never measured.
- Treating every bug-bounty finding as actively exploited, or the reverse. Art 3(42) requires reliable evidence of malicious exploitation.

Template 7 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.

8 · Article 14 notifications

These forms prepare the three Art 14 notifications for an actively exploited vulnerability (AEV) or a severe incident (SI), plus the notice to users. Art 14 has applied since 11 Sep 2026 to every in-scope product, including products already on the market (Art 69(3)). Each notification is filed on ENISA's Single Reporting Platform (SRP) to the coordinator CSIRT of the main-establishment Member State, with ENISA given simultaneous access (Art 14(7)); the internal case file stays the authoritative record.

At a glance

Item	Detail
Legal basis	Art 14(1)-(8); Art 3(42); Art 14(5); Art 69(3); Art 64(10)(a); guidance C(2026) 5252 paras 210-221 (approved draft, not formally adopted as at 30 Oct 2026)
Needed for	Every AEV and SI in any product placed on the market, including legacy and out-of-support versions (guidance para 210)
Owner	PSIRT lead; the incident commander declares awareness; a named notification owner per stage
Approver	No approval before the early warning. Legal reviews the 72-hour notification and the final report
When to create	Pre-fill the product data now for each family. File within 24 hours of awareness
When to update	At 72 hours, at the final report, and on CSIRT request (Art 14(6)). Refresh the distribution map whenever sales change
Retention	SRP receipts, notification IDs and user-notice records with the technical documentation for 10 years or the support period (Art 13(13))
Feeds	Template 7 (intake and exploitation determination); Template 6 (user channels); Template 4, Annex VII pt 2(b); Template 2 (risk assessment update after the review)

How to complete

1. Pre-fill the product rows of each form now: name, versions, Member States, support status.
2. On any signal, open a case and assess immediately. Record the UTC awareness time once there is "a reasonable degree of certainty" (guidance para 213).
3. File the early warning within 24 hours of awareness. Do not wait for legal review.
4. Inform impacted users, and all users where appropriate, in a timely manner (Art 14(8)). The notice is not gated on the filing.
5. File the 72-hour notification. Count 72 hours from awareness, not from the early warning.
6. Track the date the fix became available internally. File the final report on time.
7. Record the SRP notification ID in the case file. Run the post-incident review and update the risk assessment.

Template

Triggers and clocks

Stage	Actively exploited vulnerability	Severe incident	Basis
Trigger	"Reliable evidence that a malicious actor has exploited it" in a system without the owner's permission	Affects, or could affect, the ability to protect "sensitive or important data or functions"; or has led, or could lead, to malicious code in the product or users' systems	Art 3(42); Art 14(5)(a)-(b)
Early warning	24 hours from awareness	24 hours from awareness	Art 14(2)(a); 14(4)(a)
Notification	72 hours from awareness	72 hours from awareness	Art 14(2)(b); 14(4)(b)
Final report	No later than 14 days after a corrective or mitigating measure is available	Within 1 month after submitting the incident notification (72-hour stage)	Art 14(2)(c); 14(4)(c)
Intermediate update	On CSIRT request	On CSIRT request	Art 14(6)

Suspicion starts triage; reasonable certainty starts the clock. Not reportable: good-faith research or bug-bounty findings without exploitation evidence, and component CVEs not exploitable or not exploited in the product (FAQ 5.2, 5.4; guidance paras 217-218). Exploitation known before 11 Sep 2026 is not reported retroactively. Record "not reportable" decisions with the same rigour.

Routing: the main establishment is where product cybersecurity decisions are predominantly taken. A wrong coordinator CSIRT "may invalidate the notification" (ENISA SRP FAQ 18). The SRP is a web form only, in English, with no API and no sandbox. Use UTC for all times and label estimates.

Illustrative scenario for the example column. AEV: on 14 Nov 2026 the PSIRT confirms from cloud logs and two customer reports that attackers replayed captured Bluetooth unlock commands to open L2 locks on firmware 3.2.0 to 3.2.4. SI: an attacker uses stolen administrator credentials to issue guest keys through the access-management cloud.

Form A: early warning (24 hours), AEV and SI

Field (SRP glossary name)	Applies to	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Type	Both	Actively exploited vulnerability or severe incident	Art 14(2)(a); 14(4)(a)	Actively exploited vulnerability
Title	Both	One line naming product and issue	SRP glossary	L2 Smart Lock: Bluetooth unlock command replay exploited
Summary	Both	What is known, in two or three sentences, with estimates labelled	SRP glossary	Replay of captured unlock commands opens locks on firmware 3.2.0-3.2.4. Two confirmed cases; scale under investigation (estimate)
Product name and version	Both	Commercial name, model, affected firmware and app versions	Art 14(2)(a)	L2 Smart Lock, SKUs L2-STD, L2-KEY, L2-RTF; firmware 3.2.0-3.2.4
Member States where product available	Both	Where available, from the distribution map	Art 14(2)(a); 14(4)(a)	DE, AT, FR, NL, BE [complete from the distribution map]
Date and time became aware	Both	UTC, matching the case file	Guidance para 213	2026-11-14 09:40 UTC
Incident suspected of unlawful or malicious acts	SI only	Yes, no or unknown	Art 14(4)(a)	SI example: Yes, stolen administrator credentials

Form B: notification (72 hours), AEV and SI

Field (SRP glossary name)	Applies to	What to enter	Basis	Example: L2 Smart Lock (illustrative)
General information	AEV: product, exploit and vulnerability. SI: general nature of the incident	Mechanism, affected functionality, attack vector with reachability note, CVE or EUVD ID once assigned	Art 14(2)(b); 14(4)(b)	Unlock tokens lack replay protection over Bluetooth. Attack vector: adjacent. CVE [pending]
Initial assessment	SI	Scope and effect on the product's security so far	Art 14(4)(b)	SI example: [n] guest keys issued to [n] locks; keys revoked
Corrective or mitigating measures taken	Both	What the manufacturer has done	Art 14(2)(b); 14(4)(b)	Cloud now rejects reused tokens; firmware 3.2.5 in test
Measures users can take	Both	Interim steps for users	Art 14(2)(b); 14(4)(b)	Turn off Bluetooth unlock in the app; use keypad unlock until updated
Considered sensitivity	Both	Manufacturer's view of how sensitive the information is	Art 14(2)(b); 14(4)(b)	High until the update is widely installed
PEC indicator	AEV only	"Particularly exceptional circumstances" request; legal decides	SRP AEV 72-hour tab	Not requested

The SRP 72-hour counter currently shows a due time 48 hours after the early warning (ENISA SRP FAQ 26). Counters are visibility aids; the statute's 72 hours from awareness governs.

Form C: final report, actively exploited vulnerability (14 days after the fix)

Field (SRP glossary name)	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Description of the vulnerability, including severity and impact	What the vulnerability is; assessed severity rating, classification and rationale; CVSS vector with plain-language reasoning. No scale is prescribed	Art 14(2)(c)(i)	High, CVSS [vector]; physical access to homes possible within Bluetooth range
Malicious actor	Information on the actor if known, else "unknown"	Art 14(2)(c)	Unknown
Details of the security update	Fix version, what it changes, how it is delivered	Art 14(2)(c)	Firmware 3.2.5 adds token nonces; automatic over-the-air update
Date corrective measure became available	Tracked internally; the SRP has no counter for this report	Art 14(2)(c)	2026-11-20; final report due by 2026-12-04

Form D: final report, severe incident (1 month after submitting the 72-hour incident notification)

Field (SRP glossary name)	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Detailed description of the incident, including severity and impact	Detailed description, severity and impact, with rationale	Art 14(4)(c)(i)	[n] locks exposed for [n] hours; no confirmed entry
Type of threat or root cause	Likely threat type or root cause	Art 14(4)(c)	Credential phishing of a cloud administrator; no MFA on one legacy account
Applied and ongoing mitigation	Measures applied and still running	Art 14(4)(c)	MFA enforced for all admin accounts; key-issuance alerting; credential review ongoing

User notice (Art 14(8))

After awareness, inform impacted users and, "where appropriate", all users in a timely manner (no fixed deadline), with the mitigating measures. Use "where appropriate, a structured, machine-readable format". Guidance paras 219-221 allow detail to go first to affected customers and more widely once mitigated. If the manufacturer is not timely, the CSIRTs may inform users. No format is named; CSAF is the obvious candidate but appears in no primary source.

```
Subject: Security notice for [product]: [action required / recommended]

What happened
[Plain description of the vulnerability or incident. No details that help
attackers.]

Who is affected
[Products, models and versions. How to check your version: [steps].]

What we are doing
[Measures taken. Fix version [x.y] expected [date] / available now.]

What you should do now
[Interim steps. Install update [x.y] when offered, or [manual steps].]

More information
Advisory: [URL] (machine-readable version: [CSAF URL])
Questions: [contact], [hours]

[Manufacturer], [date]. Reference: [advisory ID]
```

Example: L2 Smart Lock (illustrative)

```
Subject: Security notice for your L2 Smart Lock: action recommended

What happened
Attackers have opened a small number of L2 locks by replaying Bluetooth
unlock signals recorded nearby.

Who is affected
L2 Smart Locks on firmware 3.2.0 to 3.2.4. Check: app > Settings > About.

What we are doing
We have blocked reused signals in our cloud service. Firmware 3.2.5 fixes
the lock itself and installs automatically.

What you should do now
```

```
Until your lock shows 3.2.5, turn off Bluetooth unlock in the app
(Settings > Unlock methods) and unlock with the keypad.

More information
Advisory: https://www.example.com/security/advisories/[ID]
Questions: psirt@example.com, [phone], [hours]

Example Group, [date]. Reference: [advisory ID]
```

Related rules

Rule	Detail	Basis
Products already on the market	Art 14 also applies to products placed before 11 Dec 2027	Art 69(3)
After end of support	Reporting continues	Guidance para 210
Fines	Top tier: up to EUR 15,000,000 or 2.5% of worldwide annual turnover. Enforcement machinery applies from 11 Dec 2027	Art 64(2)
Micro and small enterprises	Exempt from fines for missing the 24-hour early-warning deadlines	Art 64(10)(a)
Format	No Art 14(10) implementing act adopted or drafted; the ENISA SRP glossary is the de facto format	Art 14(10)
SRP outage	Wait and file when it returns (SRP FAQ 25); some national CSIRTs accept email only once an outage is declared	ENISA SRP FAQ
Other regimes	NIS2, GDPR and DORA clocks run separately; no single filing discharges another. The proposed NIS2 Art 23(12) deeming rule is not adopted	KB, Reporting obligations

Common mistakes

- Legal review placed before the 24-hour early warning, delaying the filing.
- A stale distribution map. "Member States where product available" is required at early warning.

- Scanner hits or bug-bounty findings treated as actively exploited, or "not reportable" decisions left undocumented.
- The 72-hour clock read from the SRP counter instead of from awareness; the AEV final report date not tracked internally.
- Synthetic test reports submitted to the live SRP. Rehearse on paper; there is no sandbox.

Template 8 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.

9 · Supplier CRA clause pack

This pack gives contract clauses that let you meet your Art 13(5) due diligence duty on third-party components and your Art 13(6) duty to report component vulnerabilities upstream. Add it as a schedule to master agreements for suppliers of software, firmware, hardware with firmware, integrated SaaS or development services. It is a starting draft for legal review, not signed-off contract wording.

At a glance

Item	Detail
Legal basis	Art 13(5) due diligence; Art 13(6) upstream reporting; Art 13(8) support period; Annex I Part II(1) SBOM; Art 14 reporting
Needed for	Every supplier of an in-scope component, ranked by component risk (Recital 34)
Owner	Head of procurement
Approver	Legal counsel, with the product security officer for clauses 2-6
When to create	At contract award or renewal; before a new component enters the intake gate
When to update	At renewal, at each major component version, and when the product support period changes
Retention	Life of contract, plus 10 years after placing or the support period, whichever is longer, where it evidences diligence (Art 13(13))
Feeds	Template 2 (component risks), Template 3 (Art 13(8) third-party support), Template 4 (Annex VII pt 2(b) SBOM), Template 7 (component reports), Template 8 (Art 14 inputs)

How to complete

1. List in-scope suppliers and rank them by the risk of what they supply. Start with security-relevant components.

2. Pick Must and Should clauses per supplier from the clause index. Clauses never replace diligence.
3. Fill the placeholders. Take the support-period end date from Template 3 and the notification hours from Template 8.
4. Send the schedule with the supplier questionnaire. Ask for Commit, Partial or Refuse against each clause.
5. Score responses with the scoring table. Record the decision in the contract register and the component intake gate.
6. Legal reviews the final wording against the governing law before signature.

Template

Clause index

Clause	Purpose	CRA hook	Must / Should	Fallback if supplier refuses
1 Definitions	Ties contract terms to CRA terms	Art 3(20), 3(30), 3(42)	Must	Attach a definitions annex by reference
2 Vulnerability notification	Early notice so our 24 h and 72 h clocks can be met	Art 13(5), Art 14(2) and (4), Annex I Part II(6)	Must	Monitor supplier advisories, EUVD, NVD and OSV ourselves; intake gate rates component high risk
3 Security updates	Fixes for the whole product support period	Art 13(8), 13(9), Annex I Part II(2), (7), (8)	Must	Source code escrow or our own patching; documented replacement plan

Clause	Purpose	CRA hook	Must / Should	Fallback if supplier refuses
4 SBOM delivery	Component depth in our SBOM	Annex I Part II(1); Annex VII pts 2(b), 8; Art 13(25)	Must	Binary SCA on the delivered artefact; we generate the SBOM and mark known unknowns
5 Secure development, evidence and audit	Evidence for diligence and for reasoned requests	Art 13(5), 13(22); Recital 34; supports Annex VIII Module B pt 8 (notified-body audits of our processes)	Must for security-relevant components; Should otherwise	Questionnaire answers, scoped certificates and our own testing (fuzzing, penetration test)
6 Incident cooperation	Inputs for Art 14 reports and user information	Art 14(2), (4), (6), (8)	Must	Named contact on best efforts; build data from our own telemetry
7 End-of-life and cessation	Time to migrate before support ends	Art 13(8), 13(19), 13(23)	Must	Last-time buy; escrow; earlier redesign
8 Substantial change notice	Input to our substantial modification test	Art 3(30); guidance pts 108-110; supports our Annex VIII Module B pt 7 duty to inform the notified body	Should	Our release gate assesses every supplier release (Template 10)
9 Flow-down	Same duties on sub-suppliers	Art 13(5); Art 23 traceability	Should	Supplier lists sub-suppliers of security-relevant parts

Clause	Purpose	CRA hook	Must / Should	Fallback if supplier refuses
10 Open-source components	Keeps responsibility and upstream channel with us	Art 13(5), 13(6); guidance pts 86-88, 222-229	Must	None needed; we run the upstream channel
11 Confidentiality of vulnerability information	Embargo without blocking legal reports	Annex I Part II(4), (5); Art 14(8)	Must	Supplier CVD policy governs, with embargo dates agreed in writing
12 Liability	Cost allocation	None; we remain responsible as manufacturer	[Negotiated]	Commercial decision recorded by legal

Clause wording

Starting draft for legal review. Adapt numbering and defined terms to your master agreement. "Customer" is the manufacturer; "CRA" is Regulation (EU) 2024/2847.

1 Definitions. 1.1 "Component" means [the software, firmware, hardware with firmware, service or development deliverable] supplied under this Agreement for integration into the Products. 1.2 "Products" means [the Customer products listed in Annex A]. 1.3 "Actively Exploited Vulnerability", "Support Period" and "Substantial Modification" have the meanings in Article 3(42), 3(20) and 3(30) of the CRA. 1.4 "Severe Incident" means an incident meeting the test in Article 14(5) of the CRA. 1.5 "Aware" means having a reasonable degree of certainty after an initial assessment.

2 Vulnerability notification. 2.1 The Supplier shall notify the Customer of any Actively Exploited Vulnerability or Severe Incident affecting a Component within [x hours, suggested 12] of becoming Aware. 2.2 For other vulnerabilities rated [high or critical], notice is due within [5] business days; for all others within [30] days. 2.3 Notices go to [PSIRT mailbox] and [24/7 telephone]. They state: affected Component versions; description and severity with rating method; exploitation status and evidence; fixes, workarounds or mitigations; expected fix date; and the Supplier's disclosure plan. 2.4 The Supplier shall notify the Customer no later than it publishes any advisory on a Component vulnerability. 2.5 While an Actively Exploited Vulnerability is unmitigated, the Supplier shall update the Customer every [24] hours.

3 Security updates. 3.1 The Supplier shall declare in writing, at delivery, the support period for each Component version. 3.2 The Supplier shall provide security updates for each Component version until at least [date = end of the Customer's declared support period for the last Product unit placed with that version]. 3.3 Security updates shall be [free of charge], provided without delay in relation to the risk, and separate from functionality updates where technically feasible. 3.4 Updates shall be signed using [method] and come with advisory information sufficient for the Customer's own advisories. 3.5 The Supplier shall keep each security update available to the Customer for at least [10] years after issue.

4 SBOM delivery. 4.1 With each release of a Component, the Supplier shall deliver a machine-readable SBOM in [CycloneDX 1.6 or later / SPDX 3.0.1 or later]. 4.2 The SBOM covers at least top-level dependencies and [recurses to the first component outside the delivery scope, per BSI TR-03183-2 v2.1.0]. 4.3 Each entry states creator, name, version, licence and [SHA-512 hash], and marks known unknowns. 4.4 The SBOM shall not contain vulnerability information. The Supplier provides vulnerability status separately in [CSAF 2.0 with VEX]. 4.5 The Customer may place the SBOM in its technical documentation and supply it to a market surveillance authority or notified body. It shall not otherwise publish it without consent.

5 Secure development, evidence and audit. 5.1 The Supplier shall develop Components under a documented secure development framework [IEC 62443-4-1 / NIST SSDF / OWASP SAMM] and test them [at each release and on threat-driven triggers]. 5.2 Within [30] days of request, or [5] business days after a reasoned request from an authority or notified body, the Supplier shall provide: its EU declaration of conformity where the Component is itself a CRA product; extracts of its risk assessment and technical documentation; test reports; and certificates with scope statements. 5.3 The Customer [or a notified body acting for it] may audit the Supplier's vulnerability handling for the Components [once a year and after an Actively Exploited Vulnerability] on [20] business days' notice. 5.4 The Supplier shall cooperate with the Customer's responses to market surveillance authorities and notified bodies.

6 Incident cooperation. 6.1 Where the Customer must notify under Article 14 of the CRA, the Supplier shall promptly provide in [English]: affected versions and configurations; the nature of the exploit and the vulnerability; measures taken and measures users can take; root cause; severity and impact; any information on a malicious actor; and details and date of the fix. 6.2 The Supplier shall name a [24/7] contact who responds within [4] hours. 6.3 The Supplier shall answer requests for intermediate updates within [x hours]. 6.4 The Supplier shall not contact the Customer's users or any CSIRT about the Products without the Customer's agreement. Where the Supplier has its own legal reporting duty, it shall tell the Customer at the same time.

7 End-of-life and cessation. 7.1 The Supplier shall give at least [24] months' written notice before ending security updates or supply of a Component version, with a last-time-buy option and a migration path. 7.2 The Supplier shall give at least [6] months' notice before ceasing operations, and immediate notice of insolvency. It shall then [release escrowed source code, build tooling and signing arrangements] so the Customer can continue security updates.

8 Substantial change notice. 8.1 The Supplier shall give at least [90] days' notice of any change that may affect a Component's security properties. This includes new interfaces, protocols or remote services; changed cryptography or key management; new or changed dependencies; changed data flows; and changed intended use. 8.2 The notice includes the Supplier's security impact assessment. 8.3 Security updates that only fix vulnerabilities need no advance notice.

9 Flow-down. 9.1 The Supplier shall impose obligations no less protective than clauses 2 to 8 and 11 on sub-suppliers of security-relevant parts of the Components. 9.2 On request, the Supplier shall identify those sub-suppliers and the parts they supply. 9.3 The Supplier remains responsible for its sub-suppliers' performance.

10 Open-source components. 10.1 Nothing in this Schedule transfers the Customer's responsibility for the Products to the Supplier or to any open-source maintainer. 10.2 Where a Component contains open-source software, the Supplier shall track and apply upstream fixes. It shall report vulnerabilities it finds to the maintainer through the maintainer's disclosure channel. 10.3 The Supplier agrees that fixes either party develops to open-source code may be shared upstream in licence-compatible, machine-readable form. The Customer's [PSIRT or OSPO] coordinates this.

Internal note: open source taken directly from a project has no supplier contract. The component intake gate and your PSIRT's upstream channel cover it. The Art 13(6) duty applies from 11 Dec 2027; it ends where the maintainer already knows or no maintainer exists (guidance pts 222-229). The duty to remediate remains.

11 Confidentiality of vulnerability information. 11.1 Each party shall treat unpublished vulnerability information as Confidential Information. It may use it only to assess, fix, report or disclose the vulnerability. 11.2 The parties shall agree embargo dates, joint advisory timing, CVE or EUVD identifiers, and who informs users. 11.3 Confidentiality never prevents a party from meeting a legal reporting duty, including Article 14 of the CRA, or from informing a market surveillance authority, CSIRT, ENISA or notified body. 11.4 The Supplier shall not publish an advisory affecting the Products before the agreed date unless [the vulnerability is actively exploited and the Customer has been notified].

12 Liability. 12.1 [Allocation of remediation, withdrawal and recall costs caused by Supplier breach of this Schedule: negotiated.] 12.2 [Cap: negotiated; consider a separate cap for clauses 2, 3, 4 and 11.] 12.3 The parties acknowledge that the Customer remains

responsible as manufacturer under the CRA. Legal to confirm whether regulatory fines are recoverable under the governing law.

Supplier response scoring

Score against the component's risk, not a fixed pass mark (Recital 34). Use the same scale as the supplier questionnaire.

Response	Meaning	Action	Record
Commit	Accepts the clause as drafted or with minor edits	Accept; sign	Contract register; intake gate "approved"
Partial	Accepts in part, for example a longer notice time or no audit right	Mitigate with the clause's fallback; review at renewal	Intake gate "approved with conditions"; compensating control named
Refuse	Rejects a Must clause	Component rated high risk; documented exit plan; escalate to the procurement council	Intake gate "high risk"; exit plan owner and date
No answer in [30] days	No response	Treat as Refuse	As for Refuse

Example: L2 Smart Lock (illustrative)

Example Group has 41 in-scope suppliers; 6 are on CRA clauses (15%). The target is the top 15 by Jan 2027 and all 41 by Jun 2027.

Supplier type	Component risk	Must clauses	Response	Action
Wireless module vendor (BLE and Wi-Fi firmware)	High: unlock path	1-7, 10, 11	Partial: 48 h notice offered, not 12 h	Accept with own EUVD and advisory monitoring; renegotiate at renewal
Commercial RTOS and crypto library vendor	High: key storage	1-7, 10, 11	Commit	Sign; add to SBOM depth check

Supplier type	Component risk	Must clauses	Response	Action
Contractor building the access-management cloud	High: remote data processing	1-9, 11	Commit	Sign; flow down to its hosting provider
Lock body and motor maker (no firmware)	Out of clause scope	None	Not applicable	No CRA schedule

Common mistakes

- Treating signed clauses as the diligence. Clauses do not replace it; refusers go to the intake gate as high risk with an exit plan.
- Assuming integration moves compliance to the supplier or the open-source project. You stay responsible for the product in its entirety (guidance pts 86-88).
- Accepting a supplier support period shorter than yours. An unsupported component must be replaced or patched by you (FAQ Section 4).
- Accepting manifest-only SBOMs. Run binary SCA on the shipped artefact, because manifests miss embedded components.
- Letting a supplier publish before telling you. Its advisory can start your Art 14 clock unseen.

Template 9 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.

10 · Substantial modification assessment

This record decides whether a change to a product already on the market is a substantial modification under Art 3(30). A positive decision makes the changed version a new placing on the market (guidance pt 116). Complete it at the release gate for every release, and file it with that release's technical documentation.

At a glance

Item	Detail
Legal basis	Art 3(30); guidance C(2026) 5252 pts 104-123; Annex VIII Module B pt 7 and Module H pt 3.5; FAQ 6.3 and 6.8; Art 69(2)
Needed for	Every release or change to a product already placed, including products placed before 11 Dec 2027
Owner	Product security officer
Approver	Compliance lead; notified-body liaison where the route is Module B+C or H
When to create	At the release gate, before tagging the release
When to update	When the change scope grows before release, or when the notified body disagrees
Retention	10 years after placing or the support period, whichever is longer (Art 13(13))
Feeds	Template 1 (re-classification), Template 2 (risk delta), Template 3 (support period), Template 4 (file version), Template 5 (declaration), Template 6 (user information)

How to complete

1. Fill the change record header and link the change ticket and release.
2. Check the current risk assessment (Template 2). A change it already foresaw and assessed is not substantial.

3. Answer the four questions from guidance pt 110, each with evidence from the threat model delta.
4. Apply the decision logic. Send borderline cases to the compliance lead.
5. Run every action in the consequence table for your outcome.
6. Sign off and file the record with the release gate record.

Template

Change record header

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Product and variants	Name, type and SKUs covered	Annex V pt 1	L2 Smart Lock, 3 SKUs
Version on the market	Current version and first placing date	Art 3(21); guidance pts 13-15, Example 2	Firmware 3.4, placed [date]
Proposed release	Version and planned release date	Annex VII pt 1	Firmware 4.0, planned [Q2 2028]
Change summary	One line per change; ticket link	Art 13(7)	Remote unlock through the access-management cloud
Change type	Security update, functionality update, or both	Annex I Part II(2)	Functionality update
Separable?	Can the security fixes ship apart from the feature?	Annex I Part II(2)	Yes; 3.4.2 ships first
Conformity route and body	Module and notified body, with certificate ID	Art 32; Annex VIII	Module B+C; [body, certificate ID]
Legacy status	Placed before 11 Dec 2027?	Art 69(2)	Yes; 3.x units placed before that date
Risk assessment version	Version the test runs against	Annex VII pt 3; Template 2	RA v2.3

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Assessor and date	Name, role, date	Art 13(7)	[Name], product security officer, [date]

Four-question test (guidance pt 110)

#	Question	Answer (yes/no)	Evidence	Notes
0	Does the change alter the intended purpose, or materially change boundaries or dependencies?	[yes/no]	[Architecture diff; marketing copy]	Pt 109 exception to the security-update rule; Art 3(30)
1	Does it introduce new threat vectors?	[yes/no]	[New interfaces, ports, protocols, remote services]	Pt 110
2	Does it create new attack scenarios?	[yes/no]	[Threat model delta]	Pt 110
3	Does it change the likelihood of known attack scenarios?	[yes/no]	[Reachability, exposure, attacker effort]	Pt 110
4	Does it change the impact of known attack scenarios?	[yes/no]	[Assets, data, safety, scale]	Pt 110
5	Was the change foreseen and assessed in the current risk assessment?	[yes/no]	[Template 2 row IDs]	Foreseen changes are not substantial

Decision logic

1. If the release is a security update that reduces risk and keeps the intended purpose, it is generally not substantial, even if technically large (pt 108). Go to step 2 only for the pt 109 check.

2. If question 0 is yes, the pt 108 presumption for security updates does not apply (pt 109). A changed intended purpose is substantial (Art 3(30)); otherwise continue to the next steps.
3. If question 5 is yes and that assessment remains valid, the change is not substantial.
4. If questions 1-4 are all no and the risk assessment stays valid, the change is not substantial (pts 111-112).
5. If any of questions 1-4 is yes, test whether the changed risk affects Annex I Part I compliance. If it does, or you cannot show it does not, record the change as substantial. This step is a kit rule, not guidance text.
6. Record the outcome, the reasoning and the approver. Borderline negatives also go to the notified body under Module B.

Art 3(30) (OJ text): a change after placing on the market "which affects the compliance of the product with digital elements with the essential cybersecurity requirements set out in Part I of Annex I or which results in a modification to the intended purpose for which the product with digital elements has been assessed".

Consequence table

Action	Not substantial	Substantial modification	Basis
Placing on the market	Original placing date stands	New placing on the market for the changed version	Guidance pt 116; scope pts 13-15, Example 2
Risk assessment (Template 2)	Record this assessment; update any affected row	Re-assess, focused on the modified parts; reuse unaffected rows	Pts 122-123; Annex VII pt 3
Technical file (Template 4)	Update software versions and the SBOM for the release	New file version; earlier versions retained	Annex VII pts 1, 2(b); Art 13(13)
Declaration (Template 5)	Update "as appropriate" if identification changes	New or updated declaration for the new version	Art 28; FAQ 6.8

Action	Not substantial	Substantial modification	Basis
Notified body	Module B: inform of any change that may affect conformity	Module B: inform and seek approval as an addition to the certificate; Module H: extend the approved system through the same body	Annex VIII Module B pt 7; Module H pt 3.5; FAQ 6.3
Classification (Template 1)	No action unless core functionality changes	Re-run classification for the new version	Art 7; Annex III
Support period (Template 3)	Unchanged	Declare a period for the new version; earlier units keep theirs	Guidance pts 132-135; Art 13(8)
Testing	Regression tests	Penetration test of the product and its remote data processing	Annex I Part II(3)
User information (Template 6)	Update if security properties or update instructions change	Update for the new version	Annex II
Legacy products	Art 14 reporting already applies (Art 69(3))	Full CRA applies to the modified version	Art 69(2)

No CRA notified body was designated at checks to 8 Sep 2026. Plan any Module B+C or H change around body availability.

Worked example: L2 Smart Lock (illustrative)

Two releases are assessed separately. Release 3.4.2 fixes a BLE pairing [flaw] and rewrites much of the pairing code. Release 4.0 adds remote unlock from the app through the access-management cloud. Today unlock works only over local BLE.

Question	3.4.2 security patch	4.0 remote unlock
0 Intended purpose, boundaries or dependencies	No; same purpose and interfaces	Yes; the unlock path now crosses the internet and depends on the cloud

Question	3.4.2 security patch	4.0 remote unlock
1 New threat vectors	No	Yes; internet-reachable unlock command path
2 New attack scenarios	No	Yes; account takeover or cloud API abuse leads to unlock
3 Likelihood of known scenarios	No; replay likelihood falls	Yes; remote attackers no longer need proximity
4 Impact of known scenarios	No	Yes; unauthorised entry across the installed base at once
5 Foreseen in RA v2.3	Yes; pairing replay row	No
Outcome	Not substantial (pt 108)	Substantial modification (pts 109-110)

Actions for 4.0: re-assess the unlock and cloud rows only; issue a new technical file version and declaration; seek the notified body's approval as an addition to the Module B certificate; re-run Template 1 and record that L2 stays Annex III Class I item 17; declare a 10-year support period for 4.0 in Template 3; penetration test the lock and the access-management cloud. 4.0 units are in scope because they are placed after 11 Dec 2027. Pushing 4.0 to 3.x units placed before that date brings those units under the CRA (Art 69(2)).

Actions for 3.4.2: record this assessment, update the SBOM and version list, and log the release in the change list shared with the body.

Common mistakes

- Judging by the size of the code change. The test is risk-based; large security updates are generally not substantial (pt 108).
- Bundling a new feature into a security release and treating it as a patch. Assess the feature itself and ship it separately where feasible (Annex I Part II(2)).
- Missing small features that add unassessed risk, such as "remember me" token storage or unencrypted log export (Examples 44-45).
- Assuming a substantial modification resets or extends earlier units' support period. It does not (pts 132-135).
- Telling the notified body only about positive decisions. The Module B pt 7 duty covers any change that may affect conformity.

Template 10 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.